

Programa del curso IC-8071

Seguridad del Software

Escuela de Computación

Carrera de Ingeniería de Computación, Plan 411.

I Parte. Aspectos relativos al plan de estudios

1 Datos generales

Nombre del curso:	Seguridad del Software
Código:	IC-8071
Tipo de curso:	Teórico - Práctico
Nº de créditos:	3
Nº horas de clase por semana:	4
Nº horas extraclase por semana:	5
Ubicación en el plan de estudios:	sexto o séptimo semestre como electiva
Requisitos:	IC-5701 Compiladores e Intérpretes
Correquisitos:	Ninguno
El curso es requisito de:	Ninguno
Asistencia:	Obligatoria
Suficiencia:	No
Posibilidad de reconocimiento:	Si
Vigencia del programa:	II semestre 2021.

2 Descripción General

El curso presenta una breve reseña de los fundamentos de la seguridad del software. Donde se considerarán vulnerabilidades y vectores de ataque que pueden servir para violentar el software creado. Entre ellos: Buffer Overflows, SQL Injection, robo de sesiones, entre otros. Además también se considerarán defensas para prevenir o mitigar estos ataques incluyendo técnicas de programación, modelado de vulnerabilidades y algunas técnicas avanzadas de pruebas. Por otro lado, al final del curso se analizará el impacto de la “Seguridad por Diseño” en el proceso de desarrollo de software.

3 Objetivos

Objetivo General

Al finalizar el presente semestre, el estudiante estará en capacidad de diseñar soluciones de Software Seguro a través de mecanismos conocidos como Security by Design con el objetivo de garantizar la confidencialidad, integridad y disponibilidad de los datos en las aplicaciones.

Objetivos Específicos

Al finalizar el presente semestre, el estudiante estará en capacidad de

- Conocer escenarios de vulnerabilidad y vectores de ataque en el software.
- Evaluar las estrategias de defensa que generalmente se utilizan para prevenir y mitigar ataques hacia el software
- Diseñar software desde una perspectiva de seguridad desde su diseño y a través de todo el ciclo de desarrollo de software

4 Contenidos

La importancia de la Seguridad en el Software

- Introducción
- Historia
- ¿Qué es Seguridad del Software?
- Complejidad, Extensibilidad y Conectividad
- Implicaciones Éticas de la Seguridad del Software
- Legislación Costarricense y otros referentes

Patrones de Ataque

- Taxonomía de los patrones de Ataque

- Análisis de Riesgo en el Código Fuente
- Patrones de Ataque Comunes
- Aplicación de los patrones de ataque

Ingeniería inversa para análisis de software

- Conceptos y Herramientas
- Enfoques de Ingeniería Inversa
- Métodos de Reversión
- Decompilado y Desensamblado
- Análisis dinámico y estático de código

Explotación de Software de Servidores

- Escalación de privilegios
- Encontrar puntos de inyección
- Explotación de la confianza
- Patrones de Ataques específicos para software de servidores

Explotación de Software en Clientes

- Programas cliente como objetos de Ataque
- Cross-site Scripting (XSS)
- Client Scripts y código malicioso

Alteración de Entrada de Usuario

- Detección de Intrusos
- Tracing Code
- Creación de Solicitudes Equivalentes
- Envenenamiento del proceso de Auditoría (Audit Poisoning)

Ciclo de vida de Desarrollo de Software

- Buenas prácticas de Seguridad de Software en el Ciclo de Vida de Desarrollo de Software
- Estándares de Desarrollo de Software Seguro
- Análisis de Riesgo orientado a la arquitectura
- Marcos de Trabajo para el Análisis de Riesgo
- Casos de Abuso
- Requerimientos de Seguridad en Software

II Parte. Aspectos operativos

5 Metodología de enseñanza y aprendizaje Se emplearán técnicas de clases magistrales y desarrollo de casos por parte del profesor, en donde se desarrollarán los aspectos teóricos y prácticos más relevantes de los diferentes temas. Además se combinarán con una alta participación por parte de los estudiantes durante el transcurso de las lecciones, por medio de llamadas orales, respuestas a casos en la pizarra y de trabajos en grupo.

Se presupone que el alumno profundiza los temas abordados en la clase en las lecturas recomendadas por el profesor y que el estudiante será responsable de desarrollar los diferentes entregables que se asignen en el curso.

El profesor asumirá el papel de facilitador y el estudiante tendrá la mayor responsabilidad de su progreso.

6 Evaluación A continuación se detalla la evaluación del curso:

	%
Tareas	40
Exámenes	40
Proyectos	20
	100

7 Bibliografía Gary McGraw. Exploring Software: How to break Code. 1 Edición. Addison Wesley

Gary MaGraw. Security Software: Building Security In. 1 Edición. Addison Wesley

Michael Howard and Steve Lipner. The Security Development Lifecycle. Micro-soft Press

8 Profesor Adriana Rojas Chavarria

Email: adrojas@itcr.ac.cr

Página: <http://ec.tec.ac.cr/adrojas>

Twitter: NA

Horario y lugar de consulta: M 7:00am - 8:00am Virtual